

Technical Deep Dive—Dismantling the Proxy Engine

Target Audience: Security Architects and Penetration Testers

I. Mechanics of the "Invisible Valet"

- **TLS Termination:** The proxy engine terminates the victim's TLS session, inspects the **ESTSAUTHPERSISTENT** cookie in plaintext RAM, and relays it to the legitimate IdP.
- **Sub_Filter Logic:** The proxy live-edits HTTP responses to strip **Content Security Policy (CSP)** and **X-Frame-Options** headers, preventing the browser from identifying the injection.

II. Bypassing Advanced Defenses

- **Behavioral Gating:** Proxies now use "Bouncers" to check for robotic mouse movement or sandbox IP ranges (e.g., Microsoft/Zscaler/Palo Alto) before serving the phishing payload.
- **Trust Laundering:** Using "Open Redirects" on trusted domains to bypass Email Security Gateways.

III. The End Game: Device Bound Session Credentials (DBSC)

DBSC is the architectural solution to session hijacking. By anchoring the session to the **TPM 2.0** chip, the token becomes a "Digital Brick" if moved to another machine.

Monday Morning Checklist:

1. **Audit Admins:** Ensure Global Admins are restricted to FIDO2/WebAuthn only.
2. **Enable CAE:** Deploy Continuous Access Evaluation for near-real-time token revocation.
3. **Modernize IR:** Ensure your SOC knows that the "Session is the Soul."